



by **Shweta Sharma**
Senior Writer

It took \$58 to break Microsoft's SCCM, but a patch made it harder

News

Aug 13, 2026 • 4 mins

One of the vulnerabilities in a newly disclosed SCCM exploit chain was patched by Microsoft but the fix, allegedly, does not close the path to complete control on the Configuration Manager site server.



Credit: bluestork - shutterstock.com

Researchers at XM Cyber found that a standard domain user with no Microsoft SCCM privileges can chain multiple flaws to reach remote code execution, although the attack does require network access to the SCCM environment.

Enterprises use Microsoft System Center Configuration Manager (**SCCM** [<https://www.csoonline.com/article/2089612/open-source-scanner-can-identify-risky-microsoft-sccm-configurations.html>]) to deploy operating systems, manage patches, distribute software, and monitor compliance across large Windows fleets. XM Cyber's attack can move from an ordinary domain account to code execution as "NT AUTHORITY\SYSTEM" on the primary site server.

"After the Site Server is compromised, all of its managed clients are compromised as well, which usually means taking over all the company assets," XM Cyber's **Omri Baso** [<https://www.linkedin.com/in/omri-baso/>] told CSO.

The revealed attack chain combines four weaknesses, including a broken authorization in the AdminService upload functionality, a path-traversal flaw dubbed "CabSlip," weak code-signing validation that could be tricked with a \$58 commercial certificate, and an unsigned DLL-loading path in the SMS Executive service.

Microsoft fixed the initial authorization flaw, tracked as **CVE-2026-47301** [<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-47301>], in July, but Baso said the remaining links in the chain are not expected to be fully addressed until ConfigMgr 2609, planned for October.

The patch did not patch

The initial foothold comes from SCCM's AdminService API. Its normal extension-upload endpoint checks whether a user has the required permission, but its "chunked-upload" counterpart does not. That allows an authenticated Active Directory user to submit a malicious CAB archive without SCCM administrative privileges.

Microsoft's July fix blocks that route for standard domain users. However, the downstream chain remains reachable through another path. Users assigned the built-in Operations Administrator role, or a custom role with Create permission on "SMS_ConsoleExtensionData," can still trigger the same sequence.

But there is an important qualification here. XM Cyber said it believes organizations are unlikely to be exposed through the Operations Administrator route because it is already a highly privileged role.

Once the CAB reaches the server, CabSlip allows files to escape the intended temporary extraction directory and be written elsewhere on the filesystem. The attacker can use this

arbitrary file-write capability to replace “adsouce.dll,” a secondary library loaded by the SYSTEM-level SMS Executive service without its own signature check. When the service subsequently loads the DLL, the attacker gets code execution as SYSTEM.

A \$58 certificate can cross the trust boundary

The chain becomes particularly notable because SCCM’s signature validation does not establish that the signing certificate belongs to Microsoft or the target organization. It checks that the signature is structurally valid and non-expired, while revocation checks are disabled.

That means an attacker does not need an enterprise certificate. XM Cyber said the attack depends on a code-signing certificate and can also abuse certificates leaked online. For his own research, Baso used a Certum Open Source Developer Certificate that cost about \$58.

For defenders, XM Cyber recommends restricting network access to the AdminService API and auditing SCCM **RBAC** [<https://www.csoonline.com/article/572177/what-is-rbac-role-based-access-control-explained.html>] assignments, particularly accounts with the Operations Administrator role or equivalent Create permissions.

Teams should also monitor the Site Server’s “AdminService.log” for a “System.IO.DirectoryNotFoundException” followed by an HTTP 500 response, a pattern that can indicate the path traversal was triggered, XM Cyber added.

Unexpected modifications to adsouce.dll in the Configuration Manager installation directory can provide another detection signal.

Microsoft is reportedly working on patches for the remaining flaws. It did not immediately respond to CSO’s request for comment.

About



Policies



More



Our Network

